Chama Connect QA/Bug Bounty #1

Complete document for PDF export. Use `npm run pdf:build` (HTML + Edge) or `npx md-to-pdf docs/SUBMISSION_COMPLETE_FOR_PDF.md`; see `HACKATHON_PROPOSAL.md`.

---

1. Cover Page

Field	Content
Title	Chama Connect QA/Bug Bounty #1
Participant	Kevin Boaz Isom
Email	kevinisom9000@gmail.com
Event	ChamaConnect Virtual Hackathon (bug bounty / pre-launch feedback)
Date	Sunday, 26 April 2026 (EAT, Africa/Nairobi) — final PDF revision
Repository	https://github.com/Isomkevin/Chama-Connect-QA
Companion reference build	GitHub: MercyMurigi/Chama-Connect-2_0 — demo chama-connect-2.vercel.app (ChamaConnect 2.0 concept)

Authoritative rules: Official Submission Terms (PDF). If the info session deadline and PDF §7 differ, **follow the PDF and latest organizer message**.

---

2. Table of Contents

1. Introduction
2. Testing environment & methodology
3. Bugs & issues identified
4. Innovation & feature proposals
5. Expected impact
6. Repository & evidence index
7. Appendix A — CCQA evidence file index

---

3. Introduction & scope

3.1 Objective

Exercise **ChamaConnect** on **https://www.chamaconnect.io/** as a chama/SACCO administrator: members, contributions, income, loans, expenses, fines (including appeals), goals, shares, and settings. Document defects in **GitHub-issue style**: context, environment, numbered repro steps, expected vs actual, screenshots/video, root-cause hypothesis, proposed fix.

3.2 Judging alignment (info session + PDF)

- **Technical depth** of bugs and of proposed remediation.
- **Impact** on real FinTech problems: trust, **fraud awareness**, **traceable records**, correct **calculations**, **usability**, **performance**.
- **Clear documentation** and reproducible evidence.
- **Single PDF** narrative: **bugs first**; **innovations second** (optional but included here).

3.3 Scope

Authenticated admin flows for one test chama (**LESOM Dynamics**, group id used in routes: `69e22c983e9a7937fd3ca493`). Phases: P0 compliance → P1 journeys → P2 validation/modals → P3 safe stress (no DoS, no harmful production testing per PDF §5).

Coverage transparency: Expenses, **Income**, and **Appeals** (alongside Fines) were exercised at **route and navigation** level and through **shared UI patterns** (sidebar, modals, overlays). No **module-specific** defects were isolated beyond the cross-cutting issues **CCQA-002**, **CCQA-007**, and **CCQA-010** (nav/modal reliability). This is intentional scope honesty for judges verifying depth vs. breadth.

Supporting repo docs: `docs/QA_MASTER_TEST_PLAN.md`, `docs/QA_EXECUTION_REPORT.md`, `Hackathon-Info-Session-transcripts`.

3.4 Submission checklist (info session + PDF)

Aligned with organizer guidance (`Hackathon-Info-Session-transcripts`): **live account** on the platform; **GitHub-issue-style** write-ups (context, environment, numbered repro, expected vs actual, evidence, cause hypothesis, fix); **machine and browser** captured in §4.1; **bugs first**, **innovations second** in this single document; **public GitHub** and **no secrets**; testing **compliant** with official terms (no disruptive or harmful production behavior).

---

4. Testing environment & methodology

4.1 Environment (actual machine used for this submission)

Attribute	Value
Device	Windows desktop PC (64-bit), suitable for concurrent browser + IDE
OS	**Windows 10 / 11** — build **10.0.26200** (win32) on the test machine
Browser	**Google Chrome** (stable channel) for manual exploratory testing. **Cursor IDE embedded browser** (Chromium-based automation) used for reproducible navigation, snapshots, and screenshot capture. For strict reproducibility, record **chrome://version** (full version string) at the same time as any new evidence capture and paste into issue text or appendix.
Network	**Wi-Fi** (residential/office), no intentional throttling
Target	https://www.chamaconnect.io/
Account	Individual ChamaConnect account; **ChamaAdmin** on test group **LESOM Dynamics**

4.2 Methodology

- Systematic module coverage (sidebar + direct URLs).
- Negative tests (empty submits, modal cancel/submit cycles).
- **Phase 3:** rapid route changes, repeated theme toggle, modal open/close loops; sampled **Network** (no `5xx` in sample); noted RSC notification **chatter** (see **CCQA-012**).
- Evidence: **`Evidence_Files/`** — e.g. `20260425-1732-09.1854228.mp4`, `QA-01`–`QA-13`, `QA-BUG-01-*`, `QA-P2-*`; full recording also linked from `docs/QA_EXECUTION_REPORT.md`.

4.3 Reproducibility for judges

- Each defect below lists **severity**, **area**, **steps**, **expected/actual**, **business impact**, and **fix direction**.
- **Network-heavy** items (e.g. **CCQA-003**, **CCQA-012**): attach or retain a **HAR** from Chrome DevTools when reproducing for maintainer handoff.
- **Video:** session walkthrough referenced from `docs/QA_EXECUTION_REPORT.md` (Google Drive) plus local `Evidence_Files/*.mp4` when present in the clone.

---

5. Bugs & issues identified (primary section)

5.0 Severity summary

ID	Title (short)	Severity
CCQA-003	Duplicate write requests on stressed Save	**S1 Critical**
CCQA-001	Login route mismatch and auth-link inconsistency	**S2 High**
CCQA-002	Click interception blocks tab navigation in chama detail	**S2 High**
CCQA-004	Critical modal actions unreachable in constrained viewport	**S2 High**
CCQA-010	Modal overlay / scroll required for primary actions	**S3 Medium**
CCQA-005	Loan submission lacks clear required-field feedback	**S3 Medium**
CCQA-006	Fine submission validation feedback weak / non-visible	**S3 Medium**
CCQA-007	Viewport-dependent nav operability issues	**S3 Medium**
CCQA-008	Chart runtime error in dashboard	**S3 Medium**
CCQA-009	Excessive production logging noise	**S4 Low**
CCQA-011	Theme-stress UI reflow — truncated labels / reduced chrome until resize	**S4 Low**
CCQA-012	Dashboard notifications — redundant RSC / fetch chatter	**S4 Low**

Evidence mapping: See `Evidence_Files/` PNGs and MP4; filenames referenced in `docs/QA_EXECUTION_REPORT.md`. **CCQA-011** / **CCQA-012** are primarily documented via **Phase 3**

execution notes, console/network telemetry, and session recording — add dedicated screenshots if exporting a v2 evidence pack.

[CCQA-001] Login route mismatch and auth-link inconsistency

- **Severity:** `S2 High` | **Impact weight:** `W3 High`
- **Area:** Auth routing
- **Routes:** `/login` (404); links from `/register` and `/auth/verify`
- **Steps to reproduce:**
  1. Navigate to `/login`.
  2. Observe 404 page.
  3. From `/register` or `/auth/verify`, click login/back-to-login controls.
  4. Observe inconsistent or delayed/non-functional route behavior.
- **Actual:** Canonical login appears to be `/get-started`, while `/login` is dead. Some login links fail to route predictably.
- **Expected:** All login-related links route consistently to one valid login path.
- **Business impact:** Users can fail to authenticate or lose trust before onboarding.
- **Recommended fix:** Define one canonical login route and enforce via central route constants; add link integrity tests for all auth surfaces.
- **Screenshots / video:** Attach 404 capture + working `/get-started` path; session recording in `Evidence_Files/*.mp4`.

[CCQA-002] Click interception blocks tab navigation in chama detail

- **Severity:** `S2 High` | **Impact weight:** `W3 High`
- **Area:** Chama detail navigation
- **Steps to reproduce:**
  1. Open chama detail page.
  2. Attempt to click top tab links (e.g., Members/Overview) during specific viewport/layout states.
  3. Observe click intercepted by footer/layer.
- **Actual:** Clicks intermittently fail with “click target intercepted” by footer region.
- **Expected:** Tab links consistently clickable.
- **Business impact:** Core record-management workflows become unreliable.
- **Recommended fix:** Audit z-index/stacking contexts and fixed footer overlap; add UI tests for clickable nav across breakpoints.

[CCQA-003] Duplicate write requests on stressed Save actions

- **Severity:** `S1 Critical` | **Impact weight:** `W3 High`

- **Areas:** Chama settings save; Share config save
- **Steps to reproduce:**
  1. Open settings or shares config.
  2. Double-click save action quickly.
  3. Inspect network calls.
- **Actual:** Duplicate `PATCH` requests fired to same endpoint (both `200`).
- **Expected:** One user intent ⇒ one write request (or server-side idempotent handling).
- **Business impact:** High risk of duplicate updates/race conditions in financial config state.
- **Recommended fix:** Client-side submit lock/debounce; server-side idempotency key or duplicate-request guard.
- **Evidence:** Export HAR from DevTools when reproducing; cite in PDF.

[CCQA-004] Critical modal actions unreachable in constrained viewport

- **Severity:** `S2 High` | **Impact weight:** `W3 High`
- **Area:** Goals modal and other vertical forms
- **Steps to reproduce:**
  1. Open create-goal modal in constrained viewport state.
  2. Attempt to click Create/Close.
  3. Observe controls offscreen and not recoverable by normal scroll.
- **Actual:** Action buttons can become unreachable; users may be trapped in modal.
- **Expected:** Modal actions always reachable (sticky footer/actions or scrollable body).
- **Business impact:** Users blocked from completing or exiting critical operations.
- **Recommended fix:** Responsive modal redesign with fixed action bar; keyboard escape and focus-trap tested at small heights.
- **Evidence:** `Evidence_Files/QA-P2-04-Goals-modal-short-viewport.png` (and updated goals modal captures as applicable).

[CCQA-005] Loan submission lacks clear required-field feedback

- **Severity:** `S3 Medium` | **Impact weight:** `W2 Medium`
- **Area:** Loans → Apply Loan
- **Steps to reproduce:**
  1. Open apply-loan modal.
  2. Submit without valid purpose/amount.
  3. Observe no clear inline error guidance.
- **Actual:** Submission can fail silently or without clear, specific validation feedback.
- **Expected:** Explicit field-level errors and actionable message.
- **Business impact:** Reduced completion and user confusion in credit flow.
- **Recommended fix:** Enforce schema validation and per-field messaging.

- **Evidence:** `Evidence_Files/QA-P2-02-Loan-empty-submit-attempt.png`; full flow on MP4.

[CCQA-006] Fine submission validation feedback is weak/non-visible

- **Severity:** `S3 Medium` | **Impact weight:** `W2 Medium`
- **Area:** Fines → Add Fine
- **Steps to reproduce:**
  1. Open add-fine form.
  2. Submit empty required fields.
  3. Observe minimal/no explicit feedback.
- **Actual:** Required fields exist, but feedback is not sufficiently explicit for users (often relies on browser-native validation).
- **Expected:** Visible, field-specific required messages before submit.
- **Business impact:** Inconsistent enforcement and lower trust in governance workflows.
- **Recommended fix:** Add clear validation text and focused error handling.
- **Evidence:** `Evidence_Files/QA-P2-03-Fine-empty-submit-html5.png`, `QA-P2-03b-Fines-add-modal.png`.

[CCQA-007] Viewport-dependent nav operability issues

- **Severity:** `S3 Medium` | **Impact weight:** `W2 Medium`
- **Area:** Sidebar links
- **Steps to reproduce:**
  1. Open sidebar in constrained viewport.
  2. Click lower links (e.g., Loans/Fines/Goals).
  3. Observe repeated failure to bring element into clickable view.
- **Actual:** Lower nav items become intermittently unreachable.
- **Expected:** Sidebar allows reliable scroll and click across all entries.
- **Business impact:** Users cannot consistently access full module set.
- **Recommended fix:** Make sidebar independently scrollable with persistent pointer access.

[CCQA-008] Chart runtime error in dashboard

- **Severity:** `S3 Medium` | **Impact weight:** `W2 Medium`
- **Area:** Dashboard charts
- **Actual telemetry:** Console error indicates chart width/height computed as invalid (`-1`).
- **Expected:** Chart containers always resolve valid dimensions.
- **Business impact:** Unstable analytics visuals; potential blank/broken charts.
- **Recommended fix:** Enforce min dimensions and safe chart rendering guards.

[CCQA-009] Excessive production logging noise

- **Severity:** `S4 Low` | **Impact weight:** `W1 Low`
- **Area:** Client runtime
- **Actual telemetry:** Repeated token and object debug logs in production context.
- **Expected:** Sensitive/noisy debug logs gated behind non-production flags.
- **Business impact:** Harder incident diagnosis, unnecessary console noise.
- **Recommended fix:** Strip or gate verbose logs in production builds.

[CCQA-010] Modal full-screen overlay intercepts clicks until user scrolls primary actions into view

- **Severity:** `S3 Medium` | **Impact weight:** `W2 Medium` (elevate to `S2` if reproduced without workaround on common devices)
- **Area:** Financial modals (Contributions, Loans, Fines, Goals patterns)
- **Steps to reproduce:**
  1. Open a modal with a scrollable body (e.g., **Record Contribution**).
  2. Attempt **Submit** or **Cancel** without scrolling.
  3. Observe click interception or no-op until `scrollIntoView` / manual scroll exposes the control.
- **Actual:** Automation and manual-equivalent clicks can hit a `fixed inset-0` layer or miss stacked controls; **scrollIntoView** on the target button makes **Submit** / **Cancel** reliable. Empty-submit validation on **Make Contribution** is **visible and correct** once **Submit** is reachable.
- **Expected:** Primary actions always visible (sticky footer) or modal body scrolls automatically to focused invalid field + actions.
- **Business impact:** Users may think the app is frozen; increases failed submissions and support burden.
- **Recommended fix:** Sticky modal action bar; auto-scroll to first invalid field on submit; reduce overlay hit-target conflicts.
- **Evidence:** `Evidence_Files/QA-BUG-01-Contribution-submit-click-intercepted.png`, `QA-P2-01-Contribution-empty-validation.png`.

[CCQA-011] Theme-stress UI reflow — truncated accessible names and reduced chrome until viewport resize / reload

- **Severity:** `S4 Low` | **Impact weight:** `W1 Low` (elevate if production users report **mis-clicks** after theme changes)
- **Area:** Global chrome / responsive layout (observed on **Loans** after rapid **theme** toggle)
- **Steps to reproduce:**

    1. Authenticate and open **Loans** (`/admin/chamas/…/loans`).
    2. Click **Toggle theme** rapidly many times (safe stress; no flood beyond normal UI use).
    3. Observe primary actions in the accessibility tree (or visible button text).
    4. Without reloading, compare control **accessible names** (e.g. **Apply Loan** vs truncated **Apply**).
    5. Resize viewport to **1280×800** (or similar) and/or **hard reload** — observe labels/chrome return to expected state.
- **Actual:** After stress, snapshots showed **truncated** control names and **reduced chrome** until viewport resize and page reload normalized the UI.
- **Expected:** Theme toggling must not regress layout, labeling, or hit targets; strings and layout should remain stable across light/dark switches.
- **Business impact: Accessibility** and **trust** risk if users see ambiguous actions (**Apply** vs **Apply Loan**); possible contributor to mis-taps in financial modules.
- **Recommended fix:** Isolate theme transition from layout reflow (CSS containment / stable flex keys); add visual regression or component test for loans header actions after `N` theme toggles.
- **Evidence:** `docs/QA_EXECUTION_REPORT.md` § Phase 3 (rapid UI stress); session **MP4**; optional follow-up PNG export.

[CCQA-012] Dashboard notifications — redundant RSC / fetch chatter after navigation

- **Severity:** `S4 Low` | **Impact weight:** `W1 Low`
- **Area:** Client data fetching / React Server Components traffic
- **Steps to reproduce:**
    1. Perform **Phase 3** route churn (e.g. loans → dashboard → contributions).
    2. Open Chrome **Network**; filter XHR/fetch or search for `notifications` and `_rsc`.
    3. Observe **multiple** near-simultaneous **`GET`** requests to **`/admin/dashboard/notifications`** (and related **`_rsc`** payloads) with **varying cache-buster** query parameters.
- **Actual: Chatter** pattern — more round-trips than needed for a single logical “notifications” refresh. No **`5xx`** observed in the sampled run.
- **Expected: Deduplicated** fetches, **stable caching**, or **single-flight** client policy; backoff when tab is hidden.
- **Business impact: Mobile data**, **battery**, and **server cost** at scale; minor **perceived jank** if main thread contends with parse work.
- **Recommended fix:** Request **deduplication** / **SWR**-style cache; align **`_rsc`** invalidation granularity; profile after navigation storms.
- **Evidence:** Network panel export (HAR) attached to issue or repo; cross-reference `docs/QA_EXECUTION_REPORT.md` § Phase 3.

---

6. Innovation & feature proposals (Section 2)

This section complements the bug bounty by proposing **high-impact FinTech** upgrades. Several items are **grounded in the companion "ChamaConnect 2.0" codebase** at `Chama-Connect-2-point-o` (React/Vite admin, typed domain, Express LLM routes — see that repo's `README.md`, `HACKATHON_PROPOSAL.md`, and `docs/TECHNICAL_PROPOSAL.md`). They are **design references** for the production platform, not claims of deployed code on chamaconnect.io.

6.1 ICDMS-style **Cases** module + grounded **AI case suggest**

Problem: Fines/appeals and disputes lack a first-class **case** record (status, timeline, assignee, evidence).
Proposal (from 2.0): Case list/detail UI, reducer-driven transitions, `POST /api/llm/case-suggest` suggestions constrained by **group rules** snippets — reduces "AI hallucination risk" on money matters.
Impact: Direct **ICDMS optimization** track; better **traceability** for governance.
Approach: Domain `Case` model, API + audit on transition; LLM prompt includes only structured facts + policy excerpts.

6.2 **Chama AI Advisor** (CopilotKit) with optional **safe tools**

Problem: Treasurers need fast answers tied to **their** group data, not generic chat.
Proposal (from 2.0): Sidebar copilot with **grounded context** (members, balances, open cases); optional **frontend tools** (e.g. record contribution, run penalty evaluation, **simulate** M-Pesa) that mutate state through the same reducer as the UI.
Impact: Usability + operational speed; clear path to **human-in-the-loop** automation.
Approach: CopilotKit + Zod tool params; rate-limit and confirm destructive tools in production.

6.3 **Audit trail** (`pushAudit`) for sensitive mutations

Problem: CCQA-003 shows config writes can duplicate/race — operators need **who changed what, when**.
Proposal (from 2.0): Append-style **audit log** on reducer actions (settings, shares, fines, case status); Settings **Audit** tab for treasurers.
Impact: Automated records, dispute resolution, aligns with **fraud / accountability** narrative.
Approach: Immutable audit events table (when backend exists); client-first log for demo parity.

6.4 **Penalty / fine rules engine** (configurable, repeatable)

Problem: Fines feel ad hoc if not tied to published rules (CCQA-006).
Proposal (from 2.0): Versioned **fine rules** in domain; deterministic evaluation (e.g. late contribution) with explainable output before posting.

Impact: Fairness, predictability, fewer disputes.
Approach: Rule schema in DB; unit tests for edge dates and partial payments.

6.5 M-Pesa narrative: simulation → STK → reconciliation queue

Problem: Kenyan chamas run on M-Pesa; product must show a **credible** path from UX to production integration.
Proposal (from 2.0): Simulation + matching helpers today; **Daraja** STK push + signed callbacks + treasurer **reconciliation queue** as phased delivery (per `TECHNICAL_PROPOSAL.md` roadmap).
Impact: FinTech credibility; reduces treasurer spreadsheet drift.

6.6 Dashboard LLM monthly summary (grounded narrative)

Proposal (from 2.0): `POST /api/llm/monthly-summary` produces a **short narrative** from structured aggregates (not raw PII dumps).
Impact: Faster board meetings; **performance** of comprehension vs raw tables.

6.7 Governance artifacts in Settings (constitution + proposal PDF hooks)

Proposal (from 2.0): File pickers / metadata for **constitution** and **technical proposal** (filename-only in demo; real storage in prod).
Impact: Aligns group **policy** with software behavior and **ICDMS** evidence practices.

6.8 Config write integrity (closes CCQA-003 loop)

Proposal: Idempotent `PATCH` with **ETag**/version; **single-flight** client lock; server **dedupe** window.
Impact: Protects **financial config** integrity — highest ROI fix paired with audit (6.3).

---

7. Expected impact

This submission gives ChamaConnect a **prioritized, evidence-backed defect backlog** (**twelve** tracked issues **CCQA-001–012**) focused on **financial correctness, navigation reliability, governance UX**, and **performance hygiene**, plus **concrete engineering and product proposals** (including **ChamaConnect 2.0**-sourced innovations) aligned with **SACCO/chama** operations and organizer criteria: **technical depth**, **clarity**, **quantity and quality** of findings, and **impact**. The public GitHub repo, **screen recording**, and structured reports make findings **reproducible** and **low cost to verify**.

---

8. Repository & evidence index

Path	Description
`docs/QA_EXECUTION_REPORT.md`	**Chama Connect QA/Bug Bounty #1** — full log, Phase 2–3, risks, sprint order
`docs/QA_MASTER_TEST_PLAN.md`	**Chama Connect QA/Bug Bounty #1** — phased methodology
`docs/SUBMISSION_PDF_OUTLINE.md`	Short outline
`Evidence_Files/*.mp4`	Full session recording
`Evidence_Files/QA-*.png`	Screenshots
`HACKATHON_PROPOSAL.md`	GitHub-facing stub
`Hackathon-Info-Session-transcripts`	Organizer session notes

8.1 Appendix A — CCQA evidence file index (repo snapshot)

Purpose: One place for judges to open the **exact** artifact for each defect (CCQA to filename). Filenames below were **verified present** under `Evidence_Files/` in this repository (PNG list + automation `page-*` captures). Items marked **—** have no dedicated still in-repo (rely on **write-up**, **console/HAR**, or **video**).

ID	Evidence files in `Evidence_Files/`	Notes
CCQA-001	—	Capture **404 on `/login`** and working `/get-started` per write-up; full walkthrough on **Google Drive** in `docs/QA_EXECUTION_REPORT.md`.
CCQA-002	—	Repro + narrative in `docs/QA_EXECUTION_REPORT.md`; session video (Drive).
CCQA-003	—	**HAR** from DevTools not stored in repo; duplicate `PATCH` shown via Network when reproducing.
CCQA-004	`QA-P2-04-Goals-modal-short-viewport.png`	Goals modal / short viewport.

ID	Evidence files in `Evidence_Files/`	Notes
CCQA-005	`QA-P2-02-Loan-empty-submit-attempt.png`	Loan empty / unclear validation.
CCQA-006	`QA-P2-03-Fine-empty-submit-html5.png`, `QA-P2-03b-Fines-add-modal.png`	Fines / HTML5 validation context.
CCQA-007	—	Sidebar viewport issues — documented in execution report; add dedicated PNG if re-run.
CCQA-008	—	Chart dimension **console** error — see `docs/QA_EXECUTION_REPORT.md`.
CCQA-009	—	Verbose **console** logging — see report.
CCQA-010	`QA-BUG-01-Contribution-submit-click-intercepted.png`, `QA-P2-01-Contribution-empty-validation.png`	Contribution modal intercept + validation once actions reachable.
CCQA-011	—	Phase 3 theme-stress — narrative + video; optional follow-up PNG.
CCQA-012	—	Phase 3 **Network** / **HAR** — not committed; see report.

Journey / module context stills (P1 coverage; not 1:1 to a single CCQA):

`QA-01-Shares-overview.png`, `QA-02-Members-overview.png`, `QA-03-Chama-overview.png`, `QA-04-Members-page.png`, `QA-05-Contributions-page.png`, `QA-06-Income-page.png`, `QA-07-Loans-page.png`, `QA-08-Expenses-page.png`, `QA-09-Fines-page.png`, `QA-10-Fines-appeals-tab.png`, `QA-11-Goals-page.png`, `QA-12-Shares-page.png`, `QA-13-Settings-page.png`.

Automation viewport captures (general session):

`page-2026-04-25T17-31-49-250Z.png`, `page-2026-04-25T17-32-24-609Z.png`, `page-2026-04-25T17-32-44-305Z.png`, `QA-temp-modal-viewport.png`.

Video: `Evidence_Files/*.mp4` is **gitignored**; same recording is linked from **`docs/QA_EXECUTION_REPORT.md`** (Google Drive: `20260425-1732-09.1854228.mp4`).

Support (transcript): verify official support email in organizer comms (transcript mentions `support@temaconnect.io` — may be transcription error).